

Le RGPD

Table des matières

I - Contexte	3
II - S'approprier l'évolution de la collecte des données	4
A. La CNIL et la société de confiance numérique.....	4
B. Définir une donnée.....	4
C. Exercice : Quiz.....	6
III - Comprendre et mettre en place les grands principes du RGPD	8
A. De la loi informatique et libertés au RGPD : une évolution agile	8
B. Le rôle de la CNIL aujourd'hui et la raison d'être du RGPD	8
C. Collecter de la donnée grâce au recueil du consentement	9
D. Attention, sanctions !	9
E. Exercice : Quiz.....	10
IV - Les étapes pour se mettre en conformité	12
A. L'entreprise et la démarche de conformité.....	12
B. La conformité au RGPD selon Pierre CAT.....	13
C. Le RGPD et le renforcement du droit des personnes.....	16
D. Sensibiliser les salariés au RGPD.....	17
E. Exercice : Quiz.....	19
V - L'essentiel	21
VI - Auto-évaluation	22
A. Exercice.....	22
B. Test.....	22
Solutions des exercices	24

I Contexte

Contexte

Dans un contexte professionnel en constante évolution, où la collecte et l'utilisation des données occupent une place prépondérante, il est impératif de comprendre les fondements légaux qui encadrent cette pratique. L'essor fulgurant des GAFAM (Google, Apple, Facebook, Amazon, Microsoft) et autres géants du Web a amplifié les enjeux autour de la protection des données personnelles. Cette réalité a conduit à l'introduction du Règlement Général sur la Protection des Données (RGPD) le 25 mai 2018, un tournant majeur pour l'univers du commerce et de la vente. Dans ce cadre, ce cours s'attache à décrypter les subtilités entre données personnelles et données sensibles, à démystifier le rôle central de la Commission Nationale de l'Informatique et des Libertés (CNIL), et à explorer les ramifications du RGPD ainsi que les étapes cruciales pour se conformer à cette réglementation, ceci pour 2 raisons principales :

- Premièrement afin de garantir une certaine éthique dans la collecte et le traitement des données de vos clients et utilisateurs,
- Deuxièmement, afin d'éviter les sanctions auxquelles toute entreprise qui ne respecte pas le RGPD peut être confrontée.

En effet, la non-conformité aux réglementations en matière de protection des données peut entraîner des conséquences financières désastreuses pour les entreprises. Cela démarre avec de lourdes amendes et peut aller jusqu'à des pertes de réputation significatives.

Ainsi, il a été prouvé en 2018 que Facebook a partagé des quantités massives de données personnelles de ses utilisateurs avec des tiers sans leur consentement, créant ainsi des préoccupations majeures concernant la confidentialité et la sécurité des données. Ces révélations ont eu un impact direct sur la perception de la protection des données par les utilisateurs, réduisant par la même occasion la confiance des internautes vis-à-vis de Facebook.

C'est dans ce contexte que ce cours vise à vous fournir une compréhension approfondie du Règlement Général sur la Protection des Données, afin que vous puissiez bâtir des relations de confiance avec vos clients et maintenir une réputation positive auprès d'eux.

II S'approprier l'évolution de la collecte des données

A. La CNIL et la société de confiance numérique

Nous sommes témoins d'une période d'évolution marquée par l'**essor de l'économie numérique**. Au cours des dernières décennies, Internet a littéralement transformé nos vies, donnant naissance à des réseaux sociaux, des plateformes de commerce en ligne et une multitude de services accessibles en ligne. Cependant, avec cette explosion numérique, les données des individus prennent parfois une **direction inattendue**, échappant à leur contrôle.

Dans ce contexte de mutation, les entreprises, petites et grandes, se trouvent confrontées à de nouveaux défis. Parmi eux, le phénomène du **piratage informatique** menace la sécurité des données.

De ce fait, il est devenu impératif pour les entreprises de toutes tailles de se prémunir contre les **risques numériques** et de garantir la **sécurité des données**, tout en naviguant dans cet univers en constante évolution.

Pour ce faire, la CNIL (Commission Nationale de l'Informatique et des Libertés), créée en 1978, est une autorité indépendante composée d'un collège de 18 membres qui agit en tant qu'instance de surveillance et de régulation au sein de l'écosystème numérique à travers ses **4 axes stratégiques prioritaires** que sont le statut, l'organisation, les services et le nombre d'agents.

Un point important à noter concerne le rôle de la CNIL. Comme nous l'avons annoncé dans notre introduction, elle est habilitée à prononcer diverses sanctions, notamment des sanctions pécuniaires en vertu du **RGPD**. Ces sanctions peuvent atteindre jusqu'à 20 millions d'euros ou 4 % du chiffre d'affaires annuel mondial d'une entreprise, et peuvent être **rendues publiques**.

Méthode

La CNIL joue un rôle crucial dans la protection des données des citoyens français. Découvrons plus en détail sa mission dans la vidéo suivante.

B. Définir une donnée

Avant de poursuivre, commençons par définir quelques termes que nous utiliserons fréquemment tout au long du cours.

Az Définition

- **Donnée et information**

La donnée, en tant que plus infime composante de l'information, trouve son véritable sens lorsqu'elle est contextualisée et reliée à d'autres éléments au sein d'un cadre spécifique. Elle confère ainsi une valeur et une signification éclairées.

- **La donnée personnelle**

La donnée personnelle englobe les informations permettant d'identifier une personne, telles que le nom, le prénom, les pseudonymes et autres éléments facilitant la reconnaissance, y compris les comportements tracés sur les plateformes de médias sociaux dans le cadre du profilage commercial.

L'article 4 du RGPD ¹ propose la définition suivante pour la donnée à caractère personnel :

« Toute information se rapportant à une personne physique identifiée ou identifiable (ci-après dénommée « personne concernée ») ; est réputée être une « personne physique identifiable » une personne physique qui peut être identifiée, directement ou indirectement, notamment par référence à un identifiant, tel qu'un nom, un numéro d'identification, des données de localisation, un identifiant en ligne, ou à un ou plusieurs éléments spécifiques propres à son identité physique, physiologique, génétique, psychique, économique, culturelle ou sociale. »

Exemple

Vous travaillez dans une agence immobilière. Paul désire acheter sa première maison. En cliquant sur le site internet de votre agence, il est invité à remplir une fiche pour mieux comprendre ses besoins. Chaque donnée personnelle qu'il partage - son nom, son adresse, etc. - est essentielle pour que l'agence puisse le conseiller au mieux.

Autre scénario : vous travaillez dans un salon de coiffure. Émilie, une cliente habituée, y entre. Elle est invitée à remplir une fiche qui détaille ses soins capillaires préférés. Cette fiche a pour but de transformer sa routine beauté en une expérience personnalisée.

Bien que Paul et Émilie se trouvent dans des contextes différents, la collecte de données personnelles est au cœur de chaque interaction. Ces informations permettent d'offrir un service sur mesure.

Les données sensibles

Az Définition

Une donnée qualifiée de « *particulièrement sensible* » est une donnée qui bénéficie d'une **protection juridique renforcée**. Conformément à l'article 9 du RGPD, une donnée sensible est définie comme une information révélant :

- L'origine raciale ou ethnique d'une personne
- Ses opinions politiques
- Ses croyances philosophiques ou religieuses
- Son appartenance à un syndicat
- Des données génétiques
- Des données biométriques utilisées dans le but d'identifier une personne
- Des informations concernant sa santé, son orientation sexuelle ou sa vie intime

Exemple

Vanessa est une femme de 39 ans, enthousiaste à l'idée d'accueillir un nouveau membre dans sa famille.

En entrant dans la clinique où elle est suivie, elle va partager des informations personnelles délicates qui sont nécessaires pour son suivi médical. Par exemple, elle va fournir des détails sur ses antécédents médicaux, des résultats d'analyses de sang, et même des images de son échographie.

1. <https://www.cnil.fr/fr/definition/donnee-personnelle#:~:text=Une%20donn%C3%A9e%20personnelle%20est%20toute,doivent%20en%20conserver%20la%20ma%C3%A9trise>

La mise en place du RGPD assure que les informations personnelles de Vanessa, ainsi que celles de tous les patients, sont traitées en toute sécurité et confidentialité.

Donnée personnelle ou sensible

Remarque

Les salariés sont concernés par la collecte de leurs données à **plusieurs niveaux** : tout d'abord, par les données collectées par l'entreprise à leur égard dans le cadre de la gestion des ressources humaines, et ensuite, par les données collectées par l'entreprise lors de toute action de marketing ou de communication.

Pour une entreprise ou une collectivité, il est essentiel d'avoir une vigilance particulière pour les données dites « *sensibles* ».

De plus, les données d'infraction ou de condamnation pénale font l'objet de **règles spécifiques**.

Ainsi, lorsque l'entreprise ou la collectivité traite l'un de ces éléments suivants, le dispositif de traitement des données est renforcé :

- L'évaluation d'aspects personnels ou notation d'une personne, comme dans le cas du *scoring* financier,
- Une prise de décision automatisée,
- La surveillance systématique de personnes, par exemple la télésurveillance,
- Le traitement de données sensibles,
- Le traitement de données concernant des personnes vulnérables, comme les mineurs,
- Le traitement à grande échelle de données personnelles,
- Le croisement d'ensembles de données,
- Des usages innovants ou l'application de nouvelles technologies, comme les objets connectés,
- L'exclusion du bénéfice d'un droit, d'un service ou contrat, par exemple une liste noire.

Si les opérations de traitement satisfont à au moins 2 de ces 9 critères, il est recommandé d'effectuer une **analyse d'impact relative à la protection des données (DPIA)** avant de débuter ces traitements. Cette analyse d'impact sur la vie privée identifie les risques associés aux données personnelles.

C. Exercice : Quiz

[solution n°1 p. 24]

Question 1

Que signifie l'acronyme CNIL ?

Centre National d'Indication sur la Liberté

Centre National d'Information sur la Liberté

Commission Nationale de l'Informatique et des Libertés

Question 2

En quelle année la CNIL a-t-elle fait ses débuts ?

1995

1980

1978

Question 3

Quelle est la principale responsabilité de la CNIL en matière de protection des données ?

Elle développe des technologies de Cloud Computing

Elle régule et surveille l'écosystème numérique

Elle gère les réseaux sociaux et les plateformes en ligne

Question 4

Quel est le montant maximum des sanctions que la CNIL peut infliger selon le RGPD ?

Jusqu'à 1 million d'euros ou 2 % du chiffre d'affaires annuel

Jusqu'à 5 millions d'euros ou 3 % du chiffre d'affaires annuel

Jusqu'à 20 millions d'euros ou 4 % du chiffre d'affaires annuel

III Comprendre et mettre en place les grands principes du RGPD

A. De la loi informatique et libertés au RGPD : une évolution agile

La CNIL a traversé plusieurs étapes cruciales au cours de son histoire pour mieux répondre aux défis de la protection des données et à la préservation des libertés individuelles. L'année **1978** marque un tournant majeur avec la création de la loi Informatique et Libertés du 6 janvier. Sa réforme a eu lieu le 6 août 2004.

L'arrivée du RGPD le 25 mai **2018** a marqué un autre tournant. Cette nouvelle réglementation européenne a apporté une dimension sans précédent à la protection des données. Elle a introduit des concepts tels que le **consentement explicite**, la **portabilité des données** et le **droit à l'oubli**, plaçant les individus au centre de la gestion de leurs données personnelles. De plus, le RGPD a créé un cadre **harmonisé** dans toute l'Union européenne, simplifiant ainsi la conformité pour les entreprises opérant à l'échelle internationale.

La transition de la loi Informatique et Libertés vers le RGPD reflète sa nature « *agile* », une caractéristique qu'elle partage avec de nombreuses lois et réglementations. En réponse aux besoins changeants et aux avancements technologiques et sociaux, ces lois évoluent constamment pour mieux s'aligner sur un monde en constante mutation.

B. Le rôle de la CNIL aujourd'hui et la raison d'être du RGPD

La CNIL, sous le slogan « *Protéger les données personnelles, accompagner l'innovation, préserver les libertés individuelles* », joue un rôle essentiel à l'ère numérique, en particulier avec l'avènement d'Internet. Son histoire est profondément liée à la digitalisation et à la protection des données.

Elle est chargée de superviser la conformité au RGPD et ce rôle s'étend à toutes les organisations, **publiques ou privées**, qui traitent des données personnelles, qu'elles soient situées dans l'Union européenne ou qu'elles ciblent les résidents européens. En effet, le RGPD transcende les frontières, reflétant les valeurs européennes en matière de protection des données.

Ainsi, la protection des données personnelles est capitale pour toutes les entreprises, **nationales ou internationales**, opérant en Europe, car elle engendre des responsabilités envers les individus tout en préservant la compétitivité et l'intégrité des entreprises.

Qui est concerné par le RGPD ?

Toute entreprise ou collectivité, qui collecte pour son compte ou non **des données de citoyens européens**, est concernée par le RGPD. Aucune entreprise n'échappe à cette règle, quelle que soit sa taille même pour des multinationales telles que Meta, société mère des réseaux sociaux Facebook ou Instagram.

Ainsi, Mark Zuckerberg, PDG de Meta, a menacé à plusieurs reprises de fermer Facebook et Instagram en Europe. Ceci dans le but de faire pression sur les autorités européennes et le Règlement Général sur la Protection des Données. En effet, en 2020, la Cour de justice européenne avait **interdit à Facebook l'envoi des données des utilisateurs européens vers des serveurs américains**. Cette décision avait fait perdre beaucoup d'argent à Meta, qui ne peut plus proposer autant de publicités ciblées qu'avant.

Exemple

Le 15 juin 2023, la CNIL a infligé une amende de 40 millions d'euros à CRITEO, une entreprise spécialisée dans la publicité en ligne. Cette sanction a été imposée en grande partie en raison du non-respect par CRITEO de l'obligation de vérifier si les individus, dont elle traitait les données, avaient donné leur consentement.

Autre exemple, le même jour, la CNIL a infligé une amende de 150 000 € à l'entreprise KG COM en raison de son non-respect du RGPD et de la loi Informatique et Libertés. Les infractions commises par cette société comprenaient la collecte excessive de données, y compris des données sensibles, sans obtenir au préalable un consentement explicite des personnes concernées, ainsi que des lacunes dans la sécurité des données.

C. Collecter de la donnée grâce au recueil du consentement

Le principe du consentement

La collecte de données doit se faire en fonction de leur pertinence et le collecteur doit agir avec **transparence**, garantissant la traçabilité des données pour instaurer la confiance tout en préservant les **droits de l'individu**.

Depuis le RGPD, l'individu doit avoir le droit de **consulter, de rectifier ou de supprimer** les données qu'un tiers collecteur détient à son sujet. Ce dernier est tenu de sécuriser les données de manière adéquate, en les conservant dans un lieu sûr et en maîtrisant les risques associés.

En résumé, les données personnelles sont considérées comme des **actifs tangibles**, possédant de la valeur à la fois pour leur détenteur et pour l'individu concerné.

Ainsi, le RGPD renforce le principe du recueil du consentement, exigeant qu'il soit donné **volontairement, explicitement et par écrit** par la personne concernée avant que le collecteur de données puisse les utiliser. Le consentement ne peut être **présumé** et la responsabilité de prouver son obtention incombe au responsable du traitement des données. Cette responsabilité de la preuve repose sur l'entreprise, qui doit **obtenir le consentement** avant de procéder à la collecte d'informations.

Ces principes sont définis dans les articles 13 et 14 du RGPD :

- Article 13 : Informations à fournir lorsque des données à caractère personnel sont collectées auprès de la personne concernée,
- Article 14 : Informations à fournir lorsque les données à caractère personnel n'ont pas été collectées auprès de la personne concernée.

6 réflexes à adopter

 Méthode

Le RGPD représente un ensemble essentiel de règles visant à garantir la conformité et à assurer la protection des données de nos utilisateurs. Dans la vidéo qui suit, nous allons explorer **6 réflexes fondamentaux** à adopter pour garantir une conformité optimale au RGPD.

En ce qui concerne la durée de conservation des données, la CNIL propose un guide² qui vous donnera des informations détaillées en fonction de chaque cas spécifique.

Un article plus concis³ de la CNIL donne également des informations importantes sur la durée de conservation des données.

D. Attention, sanctions !

Les pénalités

Dans le cadre de l'Union européenne, le RGPD établit des **sanctions spécifiques** pour garantir la conformité des entreprises en matière de protection des données. Ces sanctions visent à encourager les entreprises à respecter scrupuleusement les obligations du RGPD, et elles sont définies dans l'article 83 du RGPD.

Le RGPD prévoit 2 types de pénalités en cas de non-respect de ses dispositions.

2. https://www.cnil.fr/sites/cnil/files/atoms/files/guide_durees_de_conservation.pdf

3. <https://www.cnil.fr/fr/les-durees-de-conservation-des-donnees>

Premièrement, il y existe des **sanctions pour les responsables du traitement**. Il s'agit des entreprises, sous-traitants, organismes de certification ou organismes de suivi des codes de conduite. Ceux-ci peuvent faire face à des pénalités pouvant aller jusqu'à **10 millions d'euros ou 2 % du chiffre d'affaires annuel mondial**, selon le montant le plus élevé. Ces obligations incluent la tenue de registres internes, la désignation de délégués à la protection des données, et d'autres responsabilités conformément au RGPD.

Ensuite, il y a des **sanctions pour violation des principes fondamentaux**. Les violations des principes fondamentaux de protection des données, telles que le non-respect de l'obligation de consentement, des conditions de consentement, des droits des personnes concernées et des transferts internationaux de données vers des destinations non européennes, sont passibles de sanctions plus sévères. Les entreprises peuvent être soumises à des amendes allant jusqu'à **20 millions d'euros ou 4 % du chiffre d'affaires annuel mondial**, selon le montant le plus élevé.

De plus, il est essentiel de noter que dans ce contexte de sanctions, il existe des acteurs clés. Nous avons déjà cité le responsable de traitement qui, en règle générale, est l'entité qui détermine les finalités et les moyens du traitement des données, mais il y a également le **DPO (Délégué à la Protection des Données)**. Celui-ci est chargé de veiller à la conformité avec le RGPD au sein de l'entreprise. Leurs rôles sont distincts, mais ils peuvent coexister au sein d'une même organisation.

Les géants du Web dans le viseur

👁 Exemple

Le 27 juin 2022, le Conseil d'État a validé la sanction de 35 millions d'euros⁴ imposée par la CNIL à Amazon en 2020. Cette sanction était le résultat du dépôt de cookies sur les ordinateurs des utilisateurs par la société, sans obtenir leur consentement préalable ni leur fournir une information adéquate.

La CNIL a imposé une amende de 50 millions d'euros à l'encontre de Google. L'entreprise est accusée de ne pas avoir respecté ses obligations en vertu du RGPD. Cette décision découle de plaintes déposées contre Google par les associations *None Of Your Business* (NOYB) et la Quadrature du Net. Ces plaintes reprochaient à Google de ne pas avoir de base juridique valide pour traiter les données personnelles de ses utilisateurs, notamment dans le cadre de la diffusion de publicités ciblées.

Le 15 avril 2022, la formation restreinte de la CNIL a infligé une amende de 1,5 million d'euros à la société DEDALUS BIOLOGIE, principalement en raison de lacunes en matière de sécurité ayant entraîné la divulgation de données médicales de près de 500 000 individus.

La formation restreinte de la CNIL

Az Définition

La formation restreinte de la CNIL se compose de **5 membres**, dont un président distinct du président de la CNIL lui-même. Elle est habilitée à imposer différentes sanctions aux responsables de traitement qui enfreignent la loi.

E. Exercice : Quiz

[solution n°2 p. 25]

Question 1

Qui est responsable de l'obtention du consentement selon le RGPD ?

A L'individu concerné

⁴ <https://www.cnil.fr/fr/cookies-le-conseil-detat-valide-la-sanction-de-2020-prononcee-par-la-cnil-contre-amazon>

B L'organisme de certification

C Le responsable du traitement des données de l'entreprise

Question 2

Quel est l'objectif majeur du RGPD au sujet du principe du recueil du consentement ?

Faciliter la collecte de données sans consentement

Donner aux individus un contrôle plus fort sur leurs données personnelles

Renforcer la sécurité des données stockées

Question 3

Quelle est l'une des principales raisons de protéger les données personnelles ?

Limitier l'accès des individus à leurs propres données

Faciliter le partage de données avec des entités étrangères

Préserver l'intégrité et la compétitivité des entreprises

Question 4

Qui est soumis à l'application du RGPD ?

Toutes les entreprises dans le monde

Uniquement les entreprises établies en France

Uniquement les entreprises américaines

Question 5

Quel est le slogan de la CNIL qui résume son rôle actuel ?

Promouvoir la collecte de données, accompagner les entreprises, garantir la sécurité des données

Protéger les entreprises, accompagner l'innovation, préserver les libertés individuelles

Protéger les données personnelles, accompagner l'innovation, préserver les libertés individuelles

IV Les étapes pour se mettre en conformité

A. L'entreprise et la démarche de conformité

L'alignement avec les exigences de conformité revêt **une dimension collective** au sein de toute entreprise. Le **DPO** - délégué à la protection des données - joue un rôle central dans cette démarche, collaborant étroitement avec les diverses parties prenantes, à savoir **les salariés et la direction**.

Une coopération essentielle s'établit notamment avec le responsable informatique et/ou du système d'information, ainsi qu'avec le responsable juridique qui contribue activement aux différentes étapes du processus de mise en conformité.

Pour guider cette démarche, la CNIL met à disposition un guide exhaustif détaillant les étapes à suivre pour se conformer efficacement au RGPD.

Approfondissons ensemble ces étapes.

Les 6 étapes principales proposées par la CNIL

 Méthode

- **Étape 1 : désigner un pilote**

La première étape cruciale consiste à désigner un pilote, une personne responsable de piloter la gouvernance des données personnelles au sein de votre structure. Cette personne, également appelée « *Délégué à la Protection des Données* », jouera un rôle essentiel en informant, conseillant et contrôlant les activités internes liées aux données personnelles.

- **Étape 2 : cartographier vos traitements de données personnelles**

Pour mesurer l'impact du RGPD sur vos activités, il est essentiel de cartographier précisément tous les traitements de données personnelles au sein de votre entreprise. La création d'un registre des traitements vous permet de mieux comprendre votre situation actuelle.

- **Étape 3 : prioriser les actions à mener**

En se basant sur le registre des traitements, il est crucial d'identifier et de prioriser les actions à entreprendre pour se conformer aux obligations du RGPD. Cette priorisation doit tenir compte des risques pesant sur les droits et les libertés des personnes concernées.

- **Étape 4 : gérer les risques**

Lorsque des traitements de données personnelles présentent des risques élevés, une Analyse d'Impact Relative à la Protection des Données (AIPD) doit être menée pour évaluer et atténuer ces risques.

- **Étape 5 : organiser les processus internes**

Pour garantir une protection continue des données personnelles, il est essentiel de mettre en place des procédures internes qui intègrent la protection des données à chaque étape des activités de votre entreprise.

- **Étape 6 : documenter la conformité**

La dernière étape consiste à documenter toutes les actions entreprises pour assurer la conformité au RGPD. Une documentation continue garantit une protection adéquate des données personnelles.

B. La conformité au RGPD selon Pierre CAT

Pierre Cat, un pionnier d'Internet en Belgique, est devenu consultant en marketing en 1987.

En 1997, il a élargi ses services pour inclure des prestations liées à Internet, comme la création de sites web et le marketing en ligne.

Il a fondé l'agence « *On Off Line* », leader en web marketing en Belgique et en France. En plus de ses activités professionnelles, il partage son expertise en donnant des conférences et des formations en marketing en ligne.

Pour aider les entreprises à se conformer au RGPD, il propose un guide de 20 étapes clés, alignées sur les directives strictes de la CNIL que voici :

1. Désignation d'un délégué à la protection des données (DPO) : cette étape implique la nomination d'une personne chargée de superviser la gestion des données personnelles et de veiller à leur protection conformément à la réglementation.
2. Attribution des moyens pour la mise en conformité : cela inclut l'allocation de ressources humaines et financières pour garantir que l'entreprise est en conformité avec les lois sur la protection des données.
3. Établissement d'un état des lieux (cartographie) : il s'agit de dresser une carte de toutes les données personnelles collectées, stockées et traitées au sein de l'entreprise, ce qui est essentiel pour une gestion efficace de la conformité.
4. Détermination de la pertinence des données récoltées : cette étape consiste à évaluer si les données collectées sont nécessaires, limitées au minimum requis, et si elles comportent des risques particuliers pour la vie privée des individus.
5. Tenue d'un registre des traitements : le RGPD exige un registre des traitements de données pour prouver la conformité et faciliter les rapports aux autorités telles que la CNIL.
6. Vérification de la nécessité d'une PIA : avant de mettre en place des mesures de conformité, il est essentiel de déterminer si une Analyse d'Impact sur la Protection des Données (AIPD) est nécessaire pour évaluer les risques liés au traitement des données personnelles.
7. Gestion des droits des personnes : cela implique la création de procédures internes pour gérer les demandes des individus concernant leurs données personnelles, y compris l'accès à leurs données et la preuve de leur consentement.
8. Modification des processus et collecte des données : les processus existants de collecte et de traitement des données doivent être révisés et modifiés pour se conformer au RGPD.
9. Renouvellement d'autorisation : les autorisations pour collecter et traiter les données personnelles doivent être revues et renouvelées conformément aux exigences du RGPD.
10. Optimisation des données existantes : il s'agit d'optimiser les fichiers de données existants pour garantir qu'ils sont conformes au RGPD et qu'ils ne contiennent que les informations nécessaires.
11. Plan d'archivage : un plan d'archivage doit être établi pour définir comment les données personnelles seront stockées et archivées tout au long de leur cycle de vie.
12. Analyse des risques en matière de sécurité : il faut évaluer les risques en matière de sécurité liés au traitement des données personnelles et mettre en place des mesures pour les atténuer.
13. Processus d'alerte de violation des données : il est nécessaire de mettre en place un processus permettant de signaler et de gérer les violations de données conformément aux exigences du RGPD.

14. Information des salariés : les employés doivent être informés des nouvelles procédures et politiques liées au RGPD et être formés sur la protection des données.
15. Changements juridiques obligatoires : il peut être nécessaire de revoir et de mettre à jour les aspects juridiques des opérations commerciales pour se conformer au RGPD.
16. Révision des contrats avec les sous-traitants : les contrats avec les fournisseurs et sous-traitants doivent être examinés et mis à jour pour garantir qu'ils respectent les exigences du RGPD.
17. Mise à jour des CGV et des déclarations de respect de la vie privée : les Conditions Générales de Vente (CGV) et les déclarations de respect de la vie privée doivent être mises à jour pour refléter les nouvelles exigences en matière de protection des données.
18. Principe du guichet unique : il permet de traiter avec une seule autorité de surveillance, même si une entreprise opère dans plusieurs pays de l'Union européenne.
19. Intégration des principes de « *privacy by design* » et « *privacy by default* » : le RGPD exige que la protection des données soit intégrée dès la conception des produits et services (*privacy by design*) et que, par défaut, seules les données nécessaires soient collectées (*privacy by default*).
20. Documentation de la mise en conformité du RGPD : il est essentiel de documenter toutes les étapes prises pour se conformer au RGPD afin de pouvoir démontrer cette conformité en cas de besoin.

La base légale et la finalité

Ainsi, lorsque nous parlons de l'utilisation des données, il est important de comprendre que chaque action, chaque collecte de données doit être **justifiée par une finalité bien déterminée**. Cette finalité représente la raison légitime pour laquelle ces données sont recueillies, traitées et utilisées. En outre, cette approche est en parfait accord avec les directives de la CNIL.

De plus, il est crucial d'adopter une approche de **collecte à minima**. Cela signifie que seules les données strictement nécessaires à la réalisation de l'objectif visé sont collectées.

En effet, éviter la surcollecte de données non pertinentes permet non seulement de limiter les risques liés à la protection des données personnelles, mais aussi de réduire la charge administrative liée à la gestion de ces informations.

Méthode

Ainsi, les entreprises doivent fonder leurs actions de conformité sur une base légale établie par la CNIL, que nous allons découvrir plus en détail dans la vidéo suivante.

+ Complément

REGISTRE DES ACTIVITÉS DE TRAITEMENT DE

Cliquez ici. Nom de l'organisme

Coordonnées du responsable de l'organisme

(responsable de traitement ou son représentant si le responsable est situé en dehors de l'UE)

Nom : Cliquez ici. Prénom : Cliquez ici.

Adresse : Cliquez ici.

CP : Cliquez ici. Ville : Cliquez ici.

Téléphone : Cliquez ici. Adresse de messagerie : Cliquez ici.

Nom et coordonnées du délégué à la protection des données

(si vous avez désigné un DPO)

Nom : Cliquez ici. Prénom : Cliquez ici.

Société (si DPO externe) : Cliquez ici.

Adresse : Cliquez ici.

CP : Cliquez ici. Ville : Cliquez ici.

Téléphone : Cliquez ici. Adresse de messagerie : Cliquez ici.

Activités de l'organisme impliquant le traitement de données personnelles

Listez ici les activités pour lesquelles vous traitez des données personnelles.

Activités	Désignation des activités
Activité 1	Cliquez ici. ex. Gestion de la paie

Registre terminé

Source : EXEMPLE DE REGISTRE⁵

Fiche de registre		ref-000
Description du traitement		
Nom / sigle		
N° / REF	ref-000	
Date de création		
Mise à jour		
Acteurs	Nom	Adresse
Responsable du traitement		
Délégué à la protection des données		
Représentant		
Responsable(s) conjoint(s)		
Finalité(s) du traitement effectué		
Finalité principale		
Sous-finalité 1		
Sous-finalité 2		
Sous-finalité 3		
Sous-finalité 4		
Sous-finalité 5		
Mesures de sécurité		
Mesures de sécurité techniques		
Mesures de sécurité organisationnelles		
Catégories de données personnelles concernées	Description	Délai d'effacement
Etat civil, identité, données d'identification, images...		
Vie personnelle (habitudes de vie, situation familiale, etc.)		

Source : CNIL⁶

Le registre des activités de traitement, exigé par le RGPD, recense les traitements de données, identifie les parties prenantes, classe les données, précise les finalités, gère les périodes de conservation et garantit la sécurité des données.

⁵ https://www.cnil.fr/sites/cnil/files/atoms/files/registre_rgpd_basique.pdf

⁶ <https://www.cnil.fr/fr>

Il sert à documenter les pratiques, évaluer les risques et planifier la conformité. Tous les organismes, quelle que soit leur taille, doivent le tenir. Le contenu inclut des détails sur les activités de traitement, et il peut être en format papier ou électronique.

Quid des sous-traitants ?

Le RGPD impose des **obligations spécifiques aux sous-traitants** qui traitent des données personnelles pour le compte d'autres entités. Les sous-traitants concernés incluent les prestataires de services informatiques, les intégrateurs de logiciels, les sociétés de sécurité informatique, les entreprises de service numérique et les agences de marketing ou de communication travaillant avec des données clients.

Ces obligations englobent des mesures de sécurité, de confidentialité et de documentation des activités liées aux données. Les sous-traitants doivent intégrer la protection des données **dès la conception de leurs services ou produits** et mettre en place des mesures pour garantir une **protection adéquate des données**.

En plus de cela, ils sont tenus de conseiller leurs clients sur la mise en œuvre des obligations du RGPD, telles que les études d'impact sur la vie privée, les notifications de violation de données, la sécurité et la contribution aux audits. De plus, ils doivent maintenir un registre détaillé de leurs activités de traitement pour leurs clients et, dans certains cas, nommer un DPO selon les mêmes critères qu'un responsable de traitement.

Pour aider à la mise en conformité des sous-traitants, la CNIL propose un guide⁷.

Exemple

L'entreprise de marketing numérique *NomadComm* agit en tant que sous-traitant pour son client, *E-Commerce Express*, en collectant et en analysant les données des clients de ce dernier pour améliorer la précision de ses publicités en ligne.

En tant que sous-traitant, l'entreprise est responsable de mettre en place des mesures de sécurité pour protéger les données de son client, garantir leur confidentialité et documenter ses activités de traitement.

De plus, *NomadComm* a l'obligation de conseiller *E-Commerce Express* sur la conformité au RGPD, ce qui inclut la réalisation d'études d'impact sur la vie privée, la notification des violations de données et la mise en place de mesures de sécurité générales.

De plus, l'entreprise doit maintenir un registre détaillé de toutes les activités de traitement qu'elle effectue pour le compte d'*E-Commerce Express*.

Dans certaines situations, *NomadComm* peut également être tenu de désigner un DPO en fonction des mêmes critères qu'un responsable de traitement.

C. Le RGPD et le renforcement du droit des personnes

Outre l'obligation pour l'entreprise de se fonder sur une base légale et de recueillir le consentement éclairé et informé de l'utilisateur, elle s'engage également à garantir le respect d'une série de droits fondamentaux qui ont été spécifiquement accordés aux individus dans le cadre du RGPD.

Ces droits confèrent aux utilisateurs un contrôle accru sur la collecte, le traitement et l'utilisation de leurs données personnelles par les entreprises. Parmi ces droits essentiels figurent :

Premièrement, le **droit d'accès et de transparence** : les utilisateurs ont le droit de demander à l'entreprise quelles données personnelles sont collectées, traitées et stockées à leur sujet, ainsi que les finalités de ce traitement.

⁷ https://www.cnil.fr/sites/cnil/files/atoms/files/rgpd-guide_sous-traitant-cnil.pdf

Deuxièmement le **droit de rectification** : les individus ont la possibilité de corriger ou de compléter leurs données personnelles inexactes ou incomplètes détenues par l'entreprise.

Ensuite, le **droit à l'effacement** (ou droit à l'oubli) : les utilisateurs ont le droit de demander la suppression de leurs données personnelles lorsque celles-ci ne sont plus nécessaires aux fins pour lesquelles elles ont été collectées ou traitées, ou lorsque le consentement a été retiré.

Il y a également le **droit à la limitation du traitement** : les individus peuvent demander la suspension temporaire du traitement de leurs données personnelles dans certaines circonstances, par exemple en cas de contestation de l'exactitude des données.

De plus, il y a le **droit à la portabilité des données** : les utilisateurs ont le droit de recevoir une copie de leurs données personnelles dans un format structuré, couramment utilisé et lisible par machine, et de les transférer à une autre entreprise si nécessaire.

Un autre élément important est le **droit d'opposition** : les individus peuvent s'opposer au traitement de leurs données personnelles à des fins de marketing direct ou pour des motifs légitimes.

Enfin, ceux-ci ont le **droit de ne pas faire l'objet de décisions automatisées**. En effet, les utilisateurs ont le droit de ne pas être soumis à des décisions basées uniquement sur un traitement automatisé, y compris le profilage, si ces décisions produisent des effets juridiques les concernant de manière significative.

En garantissant le respect de ces droits, l'entreprise démontre son engagement envers la protection des données personnelles et le respect de la vie privée de ses utilisateurs, ce qui contribue à renforcer la confiance et les relations commerciales durables.

Les usagers face à la collecte

 Méthode

Un élément crucial concernant le respect des droits des utilisateurs est lié à la question suivante : « *quand et pourquoi les avertir concernant l'usage et la collecte de leurs données ?* » Dans la vidéo suivante, nous allons tenter de répondre à cette question à travers 3 exemples concrets.

D. Sensibiliser les salariés au RGPD

Informar le personnel

Les salariés d'une entreprise jouent un rôle **primordial** dans la mise en œuvre du RGPD. Ils sont à la fois **des acteurs contribuant au respect des règles** internes de protection des données et des **parties prenantes** dont la vie privée et les données personnelles doivent être préservées.

L'entreprise a la responsabilité d'informer ses employés de manière approfondie et de recueillir leur consentement éclairé. **Les mêmes obligations qui s'appliquent aux clients s'étendent également aux salariés**. Par exemple, les employés ont le droit de demander l'accès à toutes leurs données personnelles collectées. De plus, ils ont le droit de demander des **clarifications** à leur entreprise sur divers aspects du traitement des données, tels que les objectifs, les destinataires et la période de conservation, conformément à l'article 15 du RGPD.

Les droits renforcés des salariés

 Exemple

Un de vos employés est informé de la nouvelle réglementation en matière de protection des données personnelles (RGPD). Dans l'exercice de son droit, il souhaite avoir accès à l'ensemble des informations que votre entreprise détient à son sujet.

Cependant, êtes-vous préparé à répondre de manière précise à cette demande ? Connaissez-vous l'emplacement exact où ces données sont stockées ainsi que leur finalité ?

Ainsi, il est essentiel de savoir où ces données sont stockées et comment elles sont utilisées. Il faut également prouver que ces données sont bien protégées. Si des modifications sont nécessaires, elles doivent être faites ou expliquées en toute transparence. Cela souligne l'importance de la conformité au RGPD et de la gestion efficace des données personnelles en entreprise.

Une communication interne indispensable

Il existe des outils pour sensibiliser et informer les salariés concernant le RGPD.

Pour instaurer efficacement les mesures du RGPD, 2 axes majeurs se dégagent : la **formation** et l'**information**. Une variété de supports informatifs concernant le RGPD destinés aux salariés sont disponibles. Cette liste n'est pas exhaustive :

- Notes
- Courriels
- Guides explicatifs
- Réunions de sensibilisation
- Sessions de formation dédiées
- Groupes de travail collaboratifs
- Intégration au règlement intérieur de l'entreprise

Au cœur de cette approche réside **le principe de transparence**. En informant activement les employés et en les intégrant dans le processus de mise en place du RGPD, leur engagement envers les règles établies par ce règlement se renforcera de manière significative.

Le rôle du délégué à la protection des données (DPO) est primordial dans cette démarche de communication interne. Précédemment, nous avons déjà mentionné le métier de DPO. Voyons plus en détail son rôle dans le contexte du RGPD.

Zoom sur le DPO

Le DPO, ou délégué à la protection des données, est un **acteur clé** dans le paysage de la protection des données personnelles. Mais quand une entreprise a-t-elle besoin d'un DPO ? Et comment ce rôle est-il attribué ?

La désignation d'un DPO dépend de plusieurs facteurs. Tout d'abord, la taille de l'entreprise et la nature de ses activités jouent un rôle crucial. Selon le RGPD, une entreprise a l'obligation de nommer un DPO si ses activités principales consistent en un suivi régulier et systématique à grande échelle des personnes concernées, ou si elle traite des données sensibles à grande échelle.

Il peut s'agir d'une **personne interne** à l'entreprise ou d'un **professionnel externe spécialisé** en protection des données. En effet, le choix dépend de la complexité des opérations de traitement des données et des ressources disponibles.

Enfin, celui-ci a pour mission principale de **superviser la conformité au RGPD** au sein de l'entreprise. Il agit en tant que point de contact entre l'entreprise, les autorités de protection des données et les personnes concernées. De plus, il conseille, informe et surveille les activités de traitement des données pour s'assurer qu'elles respectent les principes du RGPD.

La conservation et la destruction des données du personnel

La réglementation dispose que les données relatives à un salarié doivent être conservées pendant une période de **5 années** après son départ de l'entreprise. Cette période de conservation a une importance capitale car elle offre une marge de manœuvre pour répondre aux éventuelles demandes de l'ancien employé concernant ses données.

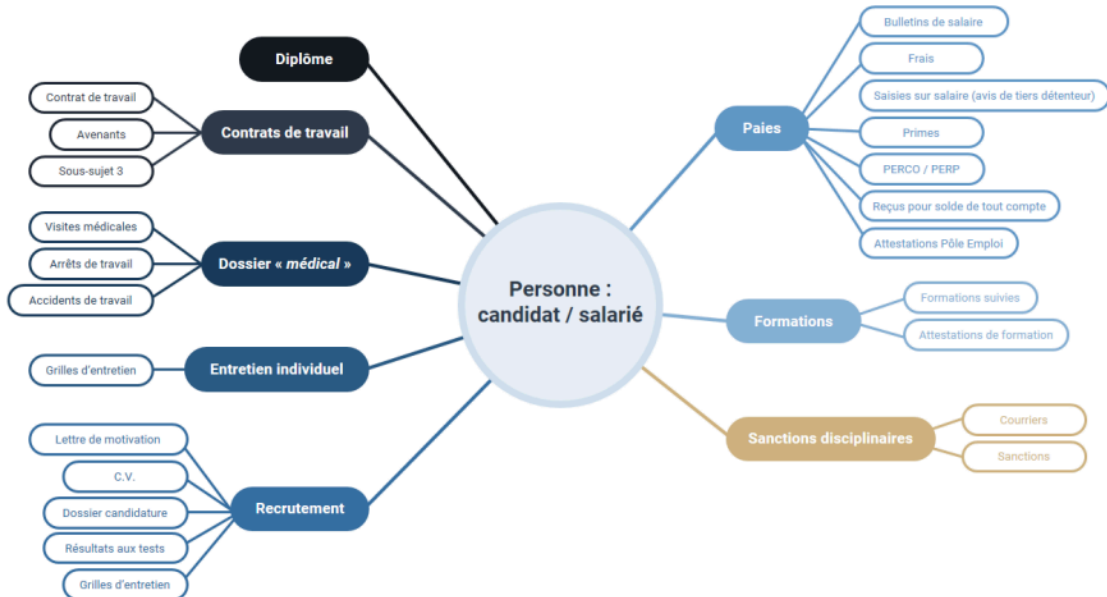
Une fois que cette période de 5 ans est écoulée, conformément à la législation, il est alors temps de procéder à la **destruction des données de manière sécurisée**.

En effet, en la matière, la législation offre des directives très précises.

Il est ainsi impératif de mettre en place une **démarche sécurisée pour détruire les données relatives à un salarié**, et ce, dans le respect le plus strict. Selon la réglementation, ces informations doivent être éliminées 5 années après le départ du collaborateur. Cette période de temps offre une certaine marge de manœuvre, durant laquelle l'ancien employé peut potentiellement solliciter **des précisions quant à ses données**, leur emplacement et leur niveau de sécurité.

Visualiser les données du salarié

Pour une visualisation plus claire des différentes catégories de données relatives aux salariés et aux candidats, voici une carte mentale :



Les informations relatives aux salariés couvrent un large éventail de données, englobant des éléments tels que les noms, prénoms, dates de naissance, adresses géographiques (données personnelles), affiliations syndicales (données sensibles), sanctions disciplinaires (données sensibles), parcours de formation (données personnelles), titres académiques, ainsi que les éléments du dossier médical (données sensibles).

E. Exercice : Quiz

[solution n°3 p. 27]

Question 1

Quel est le rôle principal d'un Délégué à la Protection des Données (DPO) au sein de l'entreprise ?

Gérer les ressources humaines

Superviser la conformité au RGPD

Gérer les comptes financiers

Question 2

Quelle est la durée maximale pendant laquelle une entreprise doit conserver les données personnelles d'un ancien employé après son départ ?

2 ans

3 ans

5 ans

Question 3

Quel droit permet aux individus de demander la suppression de leurs données personnelles lorsque celles-ci ne sont plus nécessaires aux fins pour lesquelles elles ont été collectées ?

Le droit à l'effacement

Le droit de rectification

Le droit d'opposition

Question 4

Quelle étape permet d'identifier et de prioriser les actions à entreprendre pour se conformer aux obligations du RGPD en se basant sur le registre des traitements de données personnelles ?

Cartographier les traitements de données

Gérer les risques

Mettre en place des procédures internes

Question 5

Quelle est la première étape cruciale pour se conformer au RGPD ?

Cartographier précisément les traitements de données personnelles

Établir un registre des traitements de données personnelles

Désigner un pilote ou DPO

V L'essentiel

Le Règlement Général sur la Protection des Données, communément appelé « RGPD », a marqué un tournant important dans la gestion des informations personnelles et la préservation de la vie privée, notamment *via* le principe de recueil du consentement, ou encore *via* la mise en place de mesures de sécurité des données plus importantes. En effet, cette directive européenne a profondément remanié le paysage du traitement des données, imposant des **conséquences sévères en cas de non-conformité**. Cela met en lumière l'importance capitale pour les entreprises de reconnaître leurs responsabilités dans ce domaine en mutation.

De plus, au cœur même de cette réglementation se trouvent tous les individus, de même que les salariés d'entreprise, véritables acteurs clés de cette nouvelle ère de protection des données. Ainsi, il devient impératif que les entreprises, même de plus petite envergure, entament un processus de **mise en conformité** car aujourd'hui, la confiance des clients et des partenaires commerciaux repose sur la **gestion responsable et transparente des informations personnelles**.

Il est également crucial de comprendre que le RGPD ne se limite pas à une simple obligation légale. Au contraire, c'est un élément essentiel pour témoigner de la conformité des entreprises, tout en respectant les **droits fondamentaux des individus**. Dans ce sens, il est bon de savoir que des ateliers gratuits, proposés par la CNIL, sont à disposition. Ceux-ci permettent de faciliter la compréhension des directives, mais également de faciliter leur mise en place dans les entreprises.

Soulignons également que le RGPD est une réglementation dite « **agile** ». En effet, celle-ci évolue régulièrement, et son **évolution continue**, notamment pour faire face aux défis émergents amenés par l'Intelligence Artificielle.

Pour conclure, le RGPD transcende le cadre légal. Il incarne un engagement envers la protection des droits des individus et s'adapte en permanence pour garantir **une utilisation éthique des données** à l'ère de la révolution numérique.

VI Auto-évaluation

A. Exercice

Vous êtes membre de l'équipe chargée de mettre en place un formulaire de contact pour le site web de votre entreprise. La direction vous a confié la responsabilité de concevoir ce formulaire tout en garantissant la conformité aux principes du RGPD, afin de préserver les droits et la confidentialité des utilisateurs.

Question 1

[solution n°4 p. 28]

Quels sont les principes fondamentaux qui doivent impérativement être pris en compte pour garantir cette conformité ?

Question 2

[solution n°5 p. 29]

Quelles informations personnelles doivent être incluses dans le questionnaire ?

B. Test

Exercice 1 : Quiz

[solution n°6 p. 29]

Question 1

Une donnée personnelle permet d'identifier une personne.

Vrai

Faux

Question 2

Est-ce qu'une donnée sensible est identique à une donnée personnelle ?

Oui

Non

Question 3

Quel droit permet aux individus de demander la transmission de leurs données personnelles ?

Le droit à la portabilité

Le droit de rectification

Le droit à l'oubli

Exercice

Qu'est-ce que le « *consentement éclairé* » ?

Le consentement obtenu à la suite d'une pression exercée sur l'individu

Le consentement donné par une personne ayant des connaissances préalables sur les implications de la collecte de données

Le consentement obtenu par le biais de publicités ciblées en ligne

Exercice 6

[solution n°7 p. 31]

Associez chaque mot-clé à sa définition.

Recueil du consentement de données
Sanctions administratives et pénales en cas de non-respect du RGPD
CNIL
Donnée sensible

Dossiers médicaux, antécédents médicaux, opinions politiques
Autorité administrative française indépendante, protection des données personnelles
20 millions d'euros ou 4 % du chiffre d'affaires annuel mondial d'une entreprise
Donner explicitement son accord pour que nos données soient utilisées

Solutions des exercices

Solution n°1

[exercice p. 6]

Question 1

Que signifie l'acronyme CNIL ?

Centre National d'Indication sur la Liberté

Centre National d'Information sur la Liberté

✓ Commission Nationale de l'Informatique et des Libertés

🔍 Elle est chargée de veiller à la protection des données personnelles en France.

Question 2

En quelle année la CNIL a-t-elle fait ses débuts ?

1995

1980

✓ 1978

🔍 La CNIL a été créée en 1978. Elle est l'autorité de protection des données personnelles en France depuis l'arrivée du numérique.

Question 3

Quelle est la principale responsabilité de la CNIL en matière de protection des données ?

Elle développe des technologies de Cloud Computing

✓ Elle régule et surveille l'écosystème numérique

Elle gère les réseaux sociaux et les plateformes en ligne

🔍 La CNIL régule et surveille l'écosystème numérique pour garantir la protection des données personnelles.

Question 4

Quel est le montant maximum des sanctions que la CNIL peut infliger selon le RGPD ?

Jusqu'à 1 million d'euros ou 2 % du chiffre d'affaires annuel

Jusqu'à 5 millions d'euros ou 3 % du chiffre d'affaires annuel

✓ Jusqu'à 20 millions d'euros ou 4 % du chiffre d'affaires annuel

🔍 Ça, c'est du sérieux ! Les sanctions en vertu du RGPD peuvent monter jusqu'à 20 millions d'euros ou 4 % du chiffre d'affaires annuel mondial de l'entreprise.

Solution n°2

[exercice p. 10]

Question 1

Qui est responsable de l'obtention du consentement selon le RGPD ?

A L'individu concerné

B L'organisme de certification

C Le responsable du traitement des données de l'entreprise

🔍 Selon le RGPD, c'est la responsabilité du responsable du traitement des données de prouver l'obtention du consentement de l'individu. Ce terme peut à la fois désigner l'entreprise, l'organisme de certification, comme les sous-traitants.

Question 2

Quel est l'objectif majeur du RGPD au sujet du principe du recueil du consentement ?

Faciliter la collecte de données sans consentement

✓ Donner aux individus un contrôle plus fort sur leurs données personnelles

Renforcer la sécurité des données stockées

🔍 Le RGPD vise à renforcer la confiance en donnant aux individus un contrôle plus fort sur leurs données personnelles via un consentement explicite.

Question 3

Quelle est l'une des principales raisons de protéger les données personnelles ?

Limiter l'accès des individus à leurs propres données

Faciliter le partage de données avec des entités étrangères

✓ Préserver l'intégrité et la compétitivité des entreprises



La protection des données personnelles permet aux entreprises de préserver leur intégrité et leur compétitivité tout en respectant les droits individuels.

Question 4

Qui est soumis à l'application du RGPD ?

✓ Toutes les entreprises dans le monde

Uniquement les entreprises établies en France

Uniquement les entreprises américaines



Le RGPD s'applique à toutes les entreprises, qu'elles soient établies sur le territoire de l'Union européenne ou non, si elles traitent des données personnelles de citoyens européens.

Question 5

Quel est le slogan de la CNIL qui résume son rôle actuel ?

Promouvoir la collecte de données, accompagner les entreprises, garantir la sécurité des données

Protéger les entreprises, accompagner l'innovation, préserver les libertés individuelles

✓ Protéger les données personnelles, accompagner l'innovation, préserver les libertés individuelles



Ce slogan résume le rôle actuel de la CNIL, qui consiste à protéger les données personnelles, accompagner l'innovation et préserver les libertés individuelles.

Solution n°3

[exercice p. 19]

Question 1

Quel est le rôle principal d'un Délégué à la Protection des Données (DPO) au sein de l'entreprise ?

Gérer les ressources humaines

✓ Superviser la conformité au RGPD

Gérer les comptes financiers



Le rôle principal d'un DPO est de superviser la conformité au RGPD au sein de l'entreprise. Il agit en tant que point de contact entre l'entreprise, les autorités de protection des données et les personnes concernées.

Question 2

Quelle est la durée maximale pendant laquelle une entreprise doit conserver les données personnelles d'un ancien employé après son départ ?

2 ans

3 ans

✓ 5 ans



Selon la réglementation, les données personnelles d'un ancien employé doivent être éliminées 5 ans après son départ.

Question 3

Quel droit permet aux individus de demander la suppression de leurs données personnelles lorsque celles-ci ne sont plus nécessaires aux fins pour lesquelles elles ont été collectées ?

✓ Le droit à l'effacement

Le droit de rectification

Le droit d'opposition



Le droit à l'effacement permet aux individus de demander la suppression de leurs données personnelles lorsque celles-ci ne sont plus nécessaires aux fins pour lesquelles elles ont été collectées, ou lorsque le consentement a été retiré.

Question 4

Quelle étape permet d'identifier et de prioriser les actions à entreprendre pour se conformer aux obligations du RGPD en se basant sur le registre des traitements de données personnelles ?

Cartographier les traitements de données

✓ Gérer les risques

Mettre en place des procédures internes



Cette étape vise à évaluer et à atténuer les risques liés aux traitements de données personnelles.

Question 5

Quelle est la première étape cruciale pour se conformer au RGPD ?

Cartographier précisément les traitements de données personnelles

Établir un registre des traitements de données personnelles

✓ Désigner un pilote ou DPO



La première étape cruciale est de désigner une personne responsable de piloter la gouvernance des données personnelles au sein de l'entreprise. Cette personne, également appelée « DPO », jouera un rôle essentiel en informant, conseillant et contrôlant les activités internes liées aux données personnelles.

[exercice p. 22] **Solution n°4**

Pour garantir la conformité au RGPD lors de la conception du formulaire de contact, il est important de tenir compte des principes fondamentaux suivants.

Tout d'abord, le consentement éclairé. Ici, il sera important de s'assurer que les utilisateurs donnent leur consentement de manière explicite et informée avant de collecter leurs données personnelles. Pour ce faire, nous pouvons utiliser des cases à cocher distinctes pour chaque type de traitement de données.

Deuxièmement, la finalité est limitée. En effet, il sera important de collecter uniquement les données nécessaires pour atteindre l'objectif spécifique du formulaire de contact, comme la réponse aux demandes des utilisateurs. Ainsi, nous devons éviter de collecter des données excessives ou non pertinentes. Par ailleurs, cela fait également écho au point suivant.

La minimisation des données. Ici, nous limiterons la collecte de données à celles strictement nécessaires pour répondre à la demande de l'utilisateur et éviterons de demander des informations sensibles.

Un autre point important sera de fournir aux utilisateurs des informations claires et compréhensibles sur la manière dont leurs données seront utilisées, stockées et partagées. Cela peut être fait à travers une politique de confidentialité accessible depuis le formulaire et dans le bas de page de notre site internet.

Enfin, nous informerons les utilisateurs de leurs droits en vertu du RGPD, tels que le droit d'accéder, de rectifier et de supprimer leurs données personnelles. Nous inclurons également des moyens simples pour exercer ces droits.

[exercice p. 22] **Solution n°5**

Lors de la conception du questionnaire pour recueillir des données auprès des clients, il est crucial de veiller à l'inclusion d'informations personnelles spécifiques tout en respectant les principes du RGPD. Voici les informations personnelles qui doivent être incluses dans le questionnaire :

Tout d'abord, l'identité et les coordonnées. En effet, le questionnaire peut inclure des champs pour le nom, l'adresse, l'adresse électronique et le numéro de téléphone des clients.

De plus, si le but du questionnaire est de mieux comprendre les préférences et les intérêts des clients, nous pourrions inclure des questions sur leurs choix et leurs attentes et expliquer clairement comment ces données seront utilisées pour personnaliser les services ou les offres.

Ensuite, nous pourrions ajouter une clause de consentement explicite et expliquer en détail quelles données sensibles seront collectées et dans quel but. À l'aide de cases à cocher, il sera important de demander aux clients la possibilité de donner leur consentement.

De plus, il faudra inclure des informations sur la possibilité pour les clients de retirer leur consentement à tout moment et comment ils peuvent le faire.

Enfin, nous pourrions également inclure des informations sur les mesures de sécurité mises en place pour protéger les données personnelles des clients et prévenir tout accès non autorisé aux données collectées.

Solution n°6

[exercice p. 22]

Question 1

Une donnée personnelle permet d'identifier une personne.

✓ Vrai

Faux



Une donnée personnelle est une information personnelle liée à une personne physique, comme son nom, son adresse postale, numéro de téléphone, son adresse e-mail ; elle permet donc bel et bien d'identifier une personne.

Question 2

Est-ce qu'une donnée sensible est identique à une donnée personnelle ?

Oui

✓ Non



Une donnée sensible est une sous-catégorie de données personnelles. Celle-ci concerne des informations sensibles telles que l'origine ethnique, les opinions politiques ou encore, la santé comme des dossiers médicaux ou antécédents médicaux.

Question 3

Quel droit permet aux individus de demander la transmission de leurs données personnelles ?

✓ Le droit à la portabilité

Le droit de rectification

Le droit à l'oubli



Le droit à la portabilité permet aux individus de demander la transmission de leurs données personnelles d'un service à un autre.

Exercice

Qu'est-ce que le « *consentement éclairé* » ?

Le consentement obtenu à la suite d'une pression exercée sur l'individu

✓ Le consentement donné par une personne ayant des connaissances préalables sur les implications de la collecte de données

Le consentement obtenu par le biais de publicités ciblées en ligne



Le « *consentement éclairé* » signifie que la personne donnant son consentement est pleinement consciente des conséquences de la collecte de données et des droits qui en découlent.

Solution n°7

[exercice p. 23]

Associez chaque mot-clé à sa définition.

Dossiers médicaux, antécédents médicaux, opinions politiques

Donnée sensible

Autorité administrative française indépendante, protection des données personnelles

CNIL

20 millions d'euros ou 4 % du chiffre d'affaires annuel mondial d'une entreprise

Sanctions administratives et pénales en cas de non-respect du RGPD

Donner explicitement son accord pour que nos données soient utilisées

Recueil du consentement de données



Quelques précisions :

Les données personnelles permettent d'identifier une personne, alors que les données sensibles ont la particularité supplémentaire d'avoir une incidence sur les personnes qu'elles concernent et sur leur vie privée.

Pour résumer, toutes les données sensibles sont des données personnelles, mais toutes les données personnelles ne sont pas des données sensibles.